13 · BACKGROUND

Drafter’s notes: blanks, choices to confirm, open points and sources

The notes written with the five drafts on 14 October 2026 and added to up to 23 October, as they stand. Section 3 explains each of the 72 [to confirm] choices with a suggested default; section 8 lists the sources relied on. Section 4 is summarised, with newer points, in the brief (document 00).

[In yellow] blanks to fill in before launch · [to confirm] choices the drafter marked for confirmation

Written 14 Oct 2026. These notes go with the five drafts, which now live in packages/shared/src/legal/content/ (one file each), are shown in the app (first login, and Profile > Legal) and are published at /legal/terms, /legal/privacy, /legal/refunds, /legal/dataProcessing and /legal/disclaimer on the web app. They are for you and the lawyer, not for customers.

1. The five documents

- terms.md: Terms of Service, about 5,500 words.
- privacy.md: Privacy Policy, about 4,950 words.
- refunds.md: Refund and Cancellation Policy, about 1,210 words.
- dataProcessing.md: Data Processing Terms, about 2,000 words.
- disclaimer.md: Disclaimer, about 830 words.

Who agrees to what follows the acceptance design in .work/legal1/SPEC.md: Owner, Manager and Head Chef agree to the Terms and the Privacy Policy; the Owner also agrees, for the restaurant, to the Refund and Cancellation Policy and the Data Processing Terms; the Disclaimer is part of the Terms and needs no separate tick. The texts say this too (Terms section 3).

All five use only the Markdown the app can show: #, ##, ###, paragraphs, - and 1. lists, bold and full https links. No tables, images, HTML or nested lists. No placeholder is followed by a bracket, so none can be mistaken for a link.

Facts I took from the project, not from the brief. Where the brief was silent I used what is built, as recorded in docs/STATUS.md (8 Oct and 11 to 12 Oct rows) and the code: invoices due 7 days after issue; Plans billed in advance per cycle; plan changes and cancellations take effect at the end of the cycle; pausing (no visits, no invoice, paused days not credited); first visits 3 days after subscribing; a Single service invoiced when ECCS approves its report; the sign-off taking a name, role, signature, rating and comment; optional email and profile photo; login tokens in the phone's secure storage; face templates encrypted with AES-256-GCM using a key kept outside the database; a phone locked after repeated wrong PINs; the face found on the phone and recognised on the server. Each of these that is a business choice is still marked [to confirm].

2. Placeholders to fill in (all wording identical in every file)

Fill these in once the company is registered. Search the five content files for each one.

- [Registered company name]: all five documents.
- [Company type] (private limited company, LLP or proprietorship): Terms 1, Privacy 2.
- [CIN or registration number]: Terms 1, Privacy 2. A proprietorship has no CIN; use the Udyam or Shops and Establishments number, or delete the words.

- [Registered address]: Terms 1, 25, 30; Privacy 2. Razorpay checks that the address can be found on Google.
- [GSTIN]: Terms 1.
- [support email] and [support phone]: Terms, Privacy, Refunds, Disclaimer.
- [website address]: Terms 1, Privacy 2. The legal pages will live at [website address]/legal/terms and so on (SPEC); Google Play and Razorpay need these addresses.
- [Grievance Officer name], [Grievance Officer designation], [grievance email]: Terms 30, Privacy 2 and elsewhere. It must be a real, named person. Until you hire, it can be you.
- [Data Protection Board address]: Privacy 21. The Board has no published complaint address yet (see section 7 below).

3. Every choice marked [to confirm], with my suggested default and why

There are 72 markers in the five documents; some items below cover several markers with the same value. Item 30 is a suggestion with no marker. Grouped by subject:

Contact and support

1. Support hours 9 am to 7 pm, Monday to Saturday (Terms 1). A guess at kitchen-friendly office hours; change to your real hours.
2. ECCS's own employees get a separate staff notice (Privacy 3). Supervisors' check-in location and photos are ECCS staff data, which this policy does not cover. You need a short staff notice before you employ anyone.

Services and partners

3. First visits within 3 days of subscribing (Terms 7). As built.
4. ECCS stays responsible to the restaurant for partner services, within the Terms' limits (Terms 8). Because ECCS sells and invoices them, the law is likely to treat ECCS as the seller anyway; saying so plainly is fairer and easier to defend. The partner remains responsible for its own results.
5. Chemical refills delivered by our team at a visit or as arranged (Refunds 2). Replace with how you will really deliver them.

Fees and payment

6. A Single service is invoiced when ECCS approves the report (Terms 9). As built.
7. Invoices due within 7 days (Terms 9). As built; well inside the 45 days the MSMED Act allows if ECCS registers as a micro or small enterprise.
8. Interest of 1.5% per month (18% a year) on late payment (Terms 9). Common in Indian B2B contracts. If ECCS registers on Udyam as a micro or small enterprise, section 16 of the MSMED Act gives a higher statutory rate (three times the RBI bank rate, compounded monthly) whatever the contract says.
9. Visits suspended 15 days after the due date, after 7 days' notice (Terms 9). Gives a small restaurant three weeks in total before visits stop.
10. Disputed invoices raised within 7 days (Terms 9). Worded as a request, not a bar, because section 28 of the Indian Contract Act voids clauses that cut off legal rights after a time limit.
11. 30 days' notice of a Plan price rise (Terms 9, Refunds 3). As built, the app shows the new price before the next cycle; 30 days gives a monthly customer one full cycle to decide.

Data and intellectual property

12. Anonymised statistics from many customers' data (Terms 12). Useful later (for example, average scores by area). Delete if you prefer not to.
13. No naming the restaurant in marketing without permission (Terms 16). Safer default.
14. Confidentiality lasts 3 years after the agreement (Terms 17). A usual period for small-business contracts.

Ending the agreement and data afterwards

15. ECCS may end the agreement for any reason with 30 days' notice and a refund (Terms 19). The notice and refund keep it from being an "unfair contract" (Consumer Protection Act 2019, section 2(46): ending without reasonable cause).
16. 15 days to put a breach right (Terms 19).
17. 30 days to export data after closure, then deletion within a further 60 days, 90 in all (Terms 20, Privacy 15, Data Processing 12).
18. Backups overwritten within 30 days (Terms 20, Privacy 15, Data Processing 12). Choose a backup set-up that matches when you host.

Liability

19. Liability capped at the fees paid in the 12 months before the claim (Terms 22). The usual cap for software and service contracts, and more likely to be upheld than a tiny one. A lower cap (3 or 6 months) protects ECCS more but is more likely to be challenged. Kitchen cleaning carries real risk of property damage (chimney motors, wiring, fire after degreasing) and injury. **Get public liability insurance**; with it you can keep this cap with confidence.
20. The restaurant's indemnity for staff data and content sits outside the cap (Terms 22). The restaurant controls staff data and consents, so it should carry that risk. A restaurant's lawyer may push back.
21. Report damage ideally within 48 hours (Terms 22). A request, not a bar (section 28 again).
22. ECCS's own indemnities (IP in the app; our breach of the Data Processing Terms) within the cap (Terms 23).

Changes, events and disputes

23. 15 days' notice of a material change to the Terms (Terms 24).
24. A pro rata refund if a restaurant leaves because of a material change (Terms 24). Fair, and it helps the change-by-notice clause hold up.
25. Either side may end a Plan if an outside event stops visits for 30 days (Terms 26).
26. IAMC Hyderabad appoints the arbitrator if we cannot agree (Terms 29). See section 4, point 4.
27. Fast-track arbitration for disputes under ₹10 lakh (Terms 29). Cheaper and quicker for small restaurants.

Privacy and retention

28. Staff documents (such as medical fitness certificates) in the vault are processed as employee data (Privacy 6). Confirm whether restaurants will upload staff documents, and what ECCS receives from medical camp partners.
29. Servers and storage in India (Privacy 14, Data Processing 6). True only once you host in AWS Mumbai as planned. Do not publish until it is true, or change the wording.
30. Proof photos, checklists, documents, labels and staff records kept while the account is active (Privacy 15). As built: nothing deletes them earlier. Consider deleting proof photos after 12 months to save storage and hold less personal data; if you build that, change the policy.

31. Visit records, reports and certificates kept 3 years after closure (Privacy 15). Three years is the time limit for most contract claims (Limitation Act 1963).
32. Users' account details deleted or anonymised within 1 year of the login being removed (Privacy 15). One year matches the DPDP Rules' minimum log retention (Rule 8(3)).
33. Agreement records kept 3 years after closure (Privacy 15). Proof of the contract for the same claim period.
34. Support messages kept 1 year after closure (Privacy 15).
35. Partner and vendor contacts kept up to 1 year after the relationship ends (Privacy 15).
36. Server, security and audit logs kept 1 year (Privacy 15). The brief asked for "a short period", but CERT-In requires 180 days of logs kept in India, and from May 2027 DPDP Rule 8(3) requires one year. One year meets both.
37. Employees' requests passed to the restaurant within 3 working days (Privacy 17, Data Processing 10).
38. Account deletion done within 30 days of the request (Privacy 18).

Refunds

39. No refund for the rest of the current period when a Plan is cancelled (Refunds 3). As built (cancel at end of cycle).
40. Full refund if the first Plan is cancelled within 7 days with no visit done (Refunds 3). A goodwill "cooling-off" period that costs little and builds trust.
41. Paused days not credited (Refunds 3). As built.
42. Free cancellation or rescheduling up to 24 hours before the visit window (Refunds 4, 5).
43. Wait 30 minutes for access before it counts as a late cancellation (Refunds 4).
44. Late cancellation fee 25% of a Single service (Refunds 4); for a Plan visit, the visit counts as used if no other slot is free.
45. If ECCS cancels at short notice, the restaurant gets the same 25% as a credit (Refunds 5). The E-Commerce Rules (Rule 4(7)) forbid cancellation charges unless the seller bears similar charges when it cancels; this mirror keeps us safe if those rules apply.
46. A missed visit is rescheduled within 7 days (Refunds 6); poor work reported within 48 hours is redone within 7 days.
47. Partner services: free cancellation up to 48 hours before; 50% kept with less notice; nothing back once a sample is taken or a session or camp starts (Refunds 7). Check against what your partners charge you.
48. Chemicals: report damage within 48 hours; unopened products returnable within 7 days (Refunds 8).
49. Refund decision within 7 working days, money sent within 7 working days of approval (Refunds 10). Banks typically take 5 to 7 more working days.
50. Unused credit refunded when the account closes (Refunds 10).
51. After the GST deadline for credit notes, only the pre-GST amount is refunded (Refunds 11). Once a credit note can no longer be issued, ECCS cannot recover the GST it paid. Ask your accountant.

Data Processing Terms

52. 15 days' notice before a new sub-processor of staff data (Data Processing 9).
53. Breach notice to the restaurant within 24 hours, full report within 48 hours (Data Processing 11). The brief suggested 48 hours. I chose 24 because the restaurant, as Data Fiduciary, must notify the Board "without delay" and send a detailed report within 72 hours of becoming aware (DPDP Rule 7). If ECCS took 48 hours, the restaurant would have only 24 left. 24 hours is also achievable since ECCS must report to CERT-In within 6 hours anyway.
54. 30 days' notice for an audit by the restaurant (Data Processing 13).

4. What the lawyer should look at first

1. **The legal entity.** Every document names [Registered company name]. Do not let real restaurants agree before the company exists. If any do, Terms section 27 allows the agreement to move to the company formed to carry on the business, but the lawyer should confirm whether those customers must agree again (a "novation").
2. **Face attendance.** This is the highest-risk feature. For the lawyer: (a) whether ECCS is only a Data Processor here (as drafted) given that ECCS designed the feature and writes the consent notice; (b) whether consent is truly free between employer and employee, and whether the restaurant should instead rely on the employment "legitimate use" (DPDP Act section 7(i)) with consent as an extra safeguard; (c) whether a tap in the app is "consent in writing" under SPDI Rule 5 (MeitY's 2011 press note says consent includes any electronic communication; I found no court decision); (d) the standing instruction letting ECCS delete a template when an employee asks ECCS directly (Data Processing 10); (e) the consent notice itself (app text keys face.consent.*): from May 2027, DPDP Rule 3 requires it to say how to withdraw, how to use rights and how to complain to the Board. Today it only says "tell the Owner". Add a line and a link to the Privacy Policy before then.
3. **Liability cap, indemnity and insurance** (Terms 22 and 23). If a restaurant counts as a "consumer", a consumer commission can strike out unfair terms (Consumer Protection Act 2019, sections 2(46), 49(2) and 59(2)). Whether a restaurant buying kitchen cleaning is a consumer is not settled: the Act excludes services used "for any commercial purpose", but the Supreme Court's "dominant purpose" test (National Insurance v Harsolia Motors, 2023) narrows that exclusion.
4. **Arbitration for small businesses** (Terms 29). Drafted to follow current law and good practice: (a) the arbitrator is appointed by both sides, never by ECCS alone, because one-sided appointment is invalid (Perkins Eastman, 2019; CORE v ECI-SPIC-SMO-MCML, Constitution Bench, 2024); (b) if we cannot agree, IAMC Hyderabad appoints. The alternative is asking the High Court under section 11, which is slower and needs a lawyer. IAMC charges fees (its published mediation schedule shows a ₹5,000 filing fee and admin fees from ₹20,000; it also has an MSME fee schedule I could not read), so check its arbitration fees for small claims; (c) fast track (section 29B) below ₹10 lakh; (d) consumer complaints cannot be forced into arbitration (Emaar MGF v Aftab Singh, 2018), and a micro or small supplier can go to the MSME Facilitation Council despite an arbitration clause (Gujarat State Civil Supplies v Mahakali Foods, 2022). The texts say so. **Question for the lawyer:** for claims of only a few thousand rupees, even fast-track arbitration may cost more than the claim. Consider letting either side go to court for claims below a set amount. Commercial suits of ₹3 lakh or more need pre-institution mediation first (Commercial Courts Act, section 12A).
5. **Do the Consumer Protection (E-Commerce) Rules 2020 apply?** ECCS sells its own services through its app, which fits an "inventory e-commerce entity", but the Rules protect "consumers", and restaurants may not be. I drafted as if they apply, because complying costs little: legal name, address, contacts and the Grievance Officer's name and designation are shown; complaints are acknowledged in 48 hours, given a reference number and resolved in one month; refund and cancellation terms are published; cancellation fees are mirrored (Rule 4(7)); the app's acceptance uses unticked boxes (Rule 4(8)). **Check in the app:** the booking screen should show the total price with the GST break-up before booking (Rule 7(1)(a)), and the payment screen should name the payment methods and the provider's contact (Rule 7(1)(d)).
6. **Retention and the DPDP Act.** The DPDP Act has no general "legitimate interests" ground like Europe's GDPR. Keeping records for 3 years to answer claims, and user details for 1 year, needs a basis the lawyer is comfortable with (DPDP section 8(7) allows keeping data "necessary for compliance with any law"). From May 2027, Rule 8(3) also requires keeping personal data and processing logs for at least one year from processing for government purposes. This may conflict with deleting restaurant data 90 days after

closure and with deletion on request. Privacy section 15 has a sentence covering this, but the lawyer should settle the schedule.

7. **The customer page.** It publishes ECCS's grade of a named restaurant. Risks: a restaurant disputing a low grade (defamation, negligent misstatement); diners or authorities mistaking ECCS's A+, A and B for the FSSAI Hygiene Rating (FSSAI's scheme uses one to five smileys, issued by agencies FSSAI recognises); and photos showing people. The texts repeat that ECCS is private, paid by the restaurant and not associated with FSSAI or TG-SAFE (Telangana Standards Authority for Food and Essential Drugs), and that ECCS is not an FSSAI-recognised hygiene rating audit agency. Consider whether grade letters should stay.
8. **Security standard.** Under SPDI Rule 8, ISO/IEC 27001 or an approved code, with audits, is the recognised way to show "reasonable security practices". ECCS has neither, and the texts claim no certification. Under section 43A, ECCS must show its security was reasonable if data leaks. A short written security policy and access log would help.
9. **Transfers outside India.** Push notifications go through Google's Firebase Cloud Messaging and, in the current build, Expo's push service too (STATUS, 8 Oct). Both may process notification text, which can include an employee's name, outside India. I found no country restricted under DPDP section 16. If you want staff names to stay in India, word attendance alerts without names.
10. **Pest control licence.** Commercial pest control needs a licence under rule 10 of the Insecticides Rules 1971, held by ECCS or a licensed partner. The Terms promise reasonable care and skill; doing pest control without a licence would undercut that.
11. **Minors.** A restaurant may employ 15 to 17 year olds in some jobs. Their data is a child's data under the DPDP Act (verifiable parental consent, no "tracking or behavioural monitoring"). Attendance records may count as monitoring. Face enrolment of under 18s is already refused.
12. **AI (added 14 Oct 2026, after these drafts).** The app now sends some data to Anthropic (the Claude API), which processes it in the US: photos and PDFs of licences and documents (they may name a proprietor and an address), support messages (which may name people), the restaurant's typed checklist items, SOPs and food label names, its hygiene score facts, inspection answers and the Supervisor's notes, the monitoring board's facts about outlets, and small copies of daily-checklist proof photos (which may show staff in passing). Nothing about attendance, pay, faces or clock-in photos is sent. Anthropic's commercial terms say it deletes what is sent within 30 days by default (longer for anything flagged under its usage policy), and a "zero data retention" agreement can be arranged through its sales team. **The drafts do not mention any of this yet:** Privacy section 13 (service providers) and 14 (transfers outside India) should name an AI service provider in the US and these purposes, and Data Processing section 9 should add AI processing to the sub-processor categories, because proof photos may show staff. Changing either means everyone agrees again at their next login. **Staff photos (15 Oct):** daily checklists include staff-hygiene checks ("Staff in clean uniform, hair covered"), whose proof photos show staff, faces included; the founder decided the AI camera check stays on for them. The AI judges only the uniform and hygiene items the check names and is told never to identify anyone, but the photo itself goes to Anthropic. The Privacy Policy, the Data Processing Terms (staff are the restaurant's data principals; ECCS processes for the restaurant; Anthropic would be a sub-processor) and any notice to staff should say that proof photos of staff are taken for hygiene checks and checked by an AI service outside India. **Shop boards (16 Oct):** ECCS's sales staff photograph a prospect's shop board to log a lead, and the photo goes to Anthropic to read the name, address and phone number. It shows a sign, not people, but it is a business's details taken before any agreement with it; the Privacy Policy's AI lines should cover it. Also for the lawyer: whether the Supervisor's AI-drafted inspection summary needs any statement beyond the one printed ("Drafted with AI help and checked by the inspector."). **ECCS Buddy (16 Oct):** the Owner's and Manager's chat messages, and what Buddy reads to answer them (checklists, visits, bookings, the score, licences, invoices, the plan, issues, inspections, SOPs, food labels, vendors; never phone numbers, PINs, staff names, attendance, pay or faces), go to Anthropic; the chats are kept in ECCS's database for 30 days after their last message, then

removed. The mic uses the phone's own speech recognition: on Android usually Google's service, on an iPhone Apple's, which may process the voice on their own servers. The Privacy Policy's AI lines should cover both and say how long chats are kept. **Crisis messages (19 Oct):** someone may write to Buddy that they want to die or to hurt themselves or someone else; Buddy answers with India's free Tele-MANAS line (14416, 1-800-891-4416) and 112, and tells no one. Such a message is information about a person's health, sent to Anthropic and kept 30 days like any chat: the Privacy Policy should allow for it, and the lawyer may advise whether ECCS should ever do more (it does nothing else today).

13. **ECCS's own employees (added 16 Oct 2026).** Onboarding now keeps a joining file for each team member: date of birth, addresses, an emergency contact, blood group, the type and last 4 digits of an ID (never a whole Aadhaar number; the masked Aadhaar is asked for as the document), PAN, bank account, previous employer, UAN or ESI, education, and photos or PDFs of their documents, including police verification and medical fitness certificates. Only the Super Admin and the person can see them. Claude relied on the employment "legitimate use" (DPDP Act section 7(i)), so there is no consent form; the new hire's page has a short notice of what is kept, why, who sees it and whom to ask. For the lawyer: (a) the notice's wording, and whether it needs the Rule 3 items from May 2027; (b) how long to keep a leaver's file and documents (nothing is removed by itself today); (c) the appointment letter's terms, which follow the labour codes' published format but were written by Claude (STATUS section 4, "Onboarding"); (d) whether click-to-accept is enough as the employee's acceptance; (e) the bank account and PAN are not separately encrypted. The five documents are written for restaurants and their staff; ECCS's own employees may need a short privacy notice of their own beyond the one on the joining page.
14. **ECCS staff now see some of a restaurant's checklist photos (added 20 Oct 2026).** The console's new Quality > Photos lets ECCS's Super Admin and Ops Manager open a restaurant's daily-checklist proof photos, but only the doubtful ones (a photo the app flags, for example taken far from the outlet, with a time that cannot be right, re-used, or from a checklist ticked too fast to be real), and accept them or reject them and ask for a retake. Until now ECCS could not open the restaurant's checklist photos at all, only count the doubtful ones: the checklists are the restaurant's own records (STATUS section 3: checklist problems are never sent to ECCS, 6 Oct 2026; Monitoring without the checklists, 20 Oct 2026). These photos can show staff, faces included (point 12, "Staff photos"). For the lawyer: (a) the Privacy Policy and the Data Processing Terms should say that ECCS may view doubtful checklist photos to check the record's integrity, and for what; (b) whether this fits ECCS's role as the restaurant's processor or makes it a fiduciary for that purpose; (c) whether staff need telling (a notice through the restaurant). The founder is also deciding whether these photos should stay in the queue at all (STATUS section 4, "Console plan step 3").
15. **Found while making the lawyer's pack (added 23 Oct 2026).** The pack in docs/legal-pack/ (00 is the brief, 01 the data inventory) lists every gap between these drafts and the app. Those not already above: (a) **backups:** the S3 file store keeps deleted files' old versions for 90 days and the server takes a daily snapshot (the last 7 kept), while Privacy 15 says up to 30 days; (b) **prospects** (BDE leads: contact names and phones, location, the shop-board photo, notes, follow-ups) are not covered by the Privacy Policy at all, only by point 12's AI line; (c) the **Supervisor's visit check-in** records where their phone was and its distance from the outlet, which neither the check-in button's words nor any staff notice says; (d) a **quote's link** records how many times and when it was opened; (e) the documents are in **English only** while the app works in 12 languages; (f) Privacy 6 does not list **Buddy chats** or the activity log's **device ID**; (g) the push services named should include **Expo's** (point 9) as well as Firebase.
16. **Usage counts (added 23 Oct 2026, the founder's request).** The console's new Usage page counts, for every logged-in person (restaurant Owners, Managers and Head Chefs, and ECCS's own team), how many times each day they opened each screen of the phone app or the console. Kept: the person, their role and restaurant, the day, the app, the screen's name (such as "/team/[staffId]", never which record) and the count, with the first and last time of the day; nothing about what was on the screen. Kept 365 days, then

deleted by a daily job; done on ECCS's own server, with no outside analytics tool; seen only by the Super Admin. Restaurant staff who only clock in, and diners on the customer page, are never counted. For the lawyer: (a) the Privacy Policy says "We use no advertising or analytics trackers"; this is first-party usage counting, not a tracker, but Privacy 6 ("Technical and security information") should list "which screens of the app you open, counted per day" and its purpose (improving the app and supporting restaurants that use it less) and Privacy 15 its 365 days; (b) for ECCS's own employees it is a record of how much they use the work apps, which the staff notice (point 13) should mention; whether it counts as monitoring that needs more than a notice; (c) whether improving the service is a lawful basis under the DPDP Act, which has no general "legitimate interests" ground (point 4.6), or whether it rests on the consent given to the Privacy Policy.

5. Things the documents describe that must be true before you publish them

- **Hosting** in India, with HTTPS on every address (Privacy 14 and 16).
- **Deletion jobs:** export window and deletion after closure; user details after a year; logs after a year (built for the activity log on 15 Oct: a daily job, ACTIVITY_LOG_DAYS; it keeps the IP address, phone and app of each event, which the Privacy Policy should list among what is logged); backups after 30 days. None is built.
- **Account deletion route** (Privacy 18): the Profile row (in the SPEC), the public page at [website address]/legal/privacy, and a person who handles the emails within 30 days. In Play Console, give that page as the "delete account" web link and fill in the Data safety form to match the Privacy Policy.
- **Location permission:** Google Play requires an in-app explanation before Android's own permission box when collection may surprise the user. Check the proof-photo location request has one.
- **Credits, refunds, credit notes, late fees and interest**: none is built. STATUS (8 Oct) still lists credit notes as undecided; today invoices can only be voided.
- **Visit cancellation windows and fees** (Refunds 4 and 5): check what the app lets an Owner do today.
- **Confidentiality undertakings** from anyone who works for ECCS, and written contracts with each provider that handles personal data (hosting, SMS, push, payments). The Data Processing Terms (section 7 and 9) promise these.
- **Technical access to the database** (Data Processing 6): the texts say only named technical people may reach it, and only when needed. Keep a simple record of who has access.
- **A staff privacy notice** for ECCS's own employees.
- **Vendor directory:** remove the sample vendors, or keep them clearly marked as samples (Terms 14, Disclaimer 7).
- **AI provider:** accept Anthropic's commercial terms for the account that holds the key, consider the zero data retention arrangement, and set a monthly spending limit in its console.
- **Notifications document:** these drafts add no notification. When the acceptance screen is built, docs/NOTIFICATIONS.md may want "terms updated, please agree again", "your account deletion is complete" and "breach notice" entries. Not built, per your rule.

6. The law in brief, with the dates relied on

- **DPDP Act 2023 and DPDP Rules 2025.** The Rules (G.S.R. 846(E)) and the Act's commencement notification are dated 13 November 2025 and were announced on 14 November 2025. Three phases. From 13 November 2025: the Act's definitions and the provisions setting up the Data Protection Board (Act sections 1(2), 2, 18 to 26, 35, 38 to 43, 44(1) and (3); Rules 1, 2, 17 to 21). One year later, November 2026: Consent Managers (Act sections 6(9) and 27(1)(d); Rule 4). Eighteen months later, May 2027: everything else, including notice (section 5, Rule 3), consent (section 6), legitimate uses (section 7), the

Fiduciary's duties (section 8: security, breach notice, erasure, a contract with any Data Processor), children (section 9), rights (sections 11 to 14), the duty to use the grievance process before going to the Board (section 13(3)), transfers abroad (section 16), the Board's complaint powers (section 27), penalties, and section 44(2), which deletes section 43A of the IT Act. The Rules in that phase: Rule 3 (notice: standalone, itemised data, purposes, and how to withdraw consent, use rights and complain to the Board), Rule 6 (security, including a contract term with processors and keeping logs for a year), Rule 7 (breach: tell affected people and the Board without delay, detailed report to the Board within 72 hours), Rule 8(3) (keep personal data and logs at least a year from processing), Rule 9 (publish a contact who answers questions), Rule 10 (verifiable parental consent), Rule 14 (publish how to use rights, nomination, answer grievances within at most 90 days).

- **IT Act 2000, section 43A, and the SPDI Rules 2011:** apply until May 2027. Rule 3 (sensitive data: passwords, financial details, health and medical records, sexual orientation, biometric information); Rule 4 (publish a privacy policy); Rule 5 (written consent before collecting sensitive data, notice of purpose and recipients, no longer retention than needed, a right to withdraw, a named Grievance Officer who resolves complaints within one month); Rules 6 and 7 (disclosure and transfer); Rule 8 (reasonable security, ISO/IEC 27001 as an example). MeitY's press note of 24 August 2011: consent includes any electronic communication, and a provider processing under contract for another company is outside Rules 5 and 6.
- **CERT-In directions, 28 April 2022 (in force 27 June 2022):** report cyber incidents within 6 hours; keep system logs for 180 days in India.
- **Consumer Protection Act 2019 and E-Commerce Rules 2020:** see section 4, points 3 and 5.
- **CGST Act 2017:** section 36 (keep accounts until 72 months after the due date of the annual return for that year); section 34 (credit notes no later than 30 November after the financial year, or the annual return if earlier, as amended in 2022); section 31(3)(e) (refund voucher for an advance with no supply).
- **Google Play User Data policy:** the privacy policy must be on a public web page (not a PDF), linked in the app and in Play Console, titled as a privacy policy, name the developer and a privacy contact, and state retention and deletion. Apps that create accounts must offer deletion both in the app and on the web. A link from the app to a web form or an email address is acceptable. All associated data must be deleted, not frozen, except data kept for security, fraud prevention or legal reasons, which the policy must disclose.
- **Razorpay:** the website must link About us, Contact us, Pricing, Terms and conditions, Privacy policy, and a Refund or Cancellation policy, and needs a sample invoice. Its blog also mentions a shipping policy, so Refunds section 2 covers delivery. The contact page needs the registered name, an address Google can find, a phone number and an email. You still need an About us and a Pricing page.
- **Clickwrap:** valid under the Indian Contract Act (sections 10 and 11; parties must be adults) and IT Act section 10A; Trimex v Vedanta (Supreme Court, 2010) upheld contracts made electronically. Good practice, already in the SPEC: unticked boxes, the text readable at the moment of agreeing, plain words that it is binding, and a record of who, when, which version and which device.

7. What I could not confirm

1. **The exact May 2027 date.** Eighteen months from 13 November 2025 is 13 May 2027, but commentators give 12, 13 or 14 May. The brief says the Rules were notified on 14 November. The documents say "May 2027" to stay correct either way.
2. **How to complain to the Data Protection Board.** The Board exists in law (since 13 November 2025), but as of 1 August 2026 it had no Chairperson or Members (LiveLaw), and I found no complaint portal. Hence [Data Protection Board address].
3. **The primary Gazette texts.** The Gazette PDF would not open (certificate error). Rule wording comes from dpdpa.com's rule-by-rule text and law-firm summaries (AZB, KPMG, Cyril Amarchand and others). The lawyer should check against the Gazette.

4. **Whether the E-Commerce Rules and the Consumer Protection Act apply to ECCS's B2B sales** (section 4, points 3 and 5).
5. **Whether any country is restricted under DPDP section 16** (I found none), and the contents of the Rules' Fourth Schedule exemptions for children's data.
6. **IAMC's arbitration fee schedule for small or MSME disputes.**
7. **TrustPlate.** Looked at only for which subjects a food-compliance company covers (its disclaimer covers: not government, no compliance guarantee, your responsibility, public profiles and badges, guides). No wording was taken from it or anyone else.

8. Sources

- Digital Personal Data Protection Rules, 2025, Gazette G.S.R. 846(E): https://egazette.gov.in/WriteReadData/2025/267650.pdf
- DPDP Rules, rule-by-rule text, Rule 1 (commencement): https://dpdpa.com/dpdparules/rule1.html
- DPDP Rules, Rule 3 (notice): https://dpdpa.com/dpdparules/rule3.html
- DPDP Rules, Rule 6 (security safeguards): https://dpdpa.com/dpdparules/rule6.html
- DPDP Rules, Rule 7 (breach intimation): https://dpdpa.com/dpdparules/rule7.html
- DPDP Rules, Rule 8 (erasure and one-year retention): https://dpdpa.com/dpdparules/rule8.html
- DPDP Rules, Rule 10 (children): https://dpdpa.com/dpdparules/rule10.html
- DPDP Rules, Rule 14 (rights, 90 days): https://dpdpa.com/dpdparules/rule14.html
- DPDP Act, section 8: https://www.dpdpa.com/dpdpa2023/chapter-2/section8.html
- DPDP Act, section 6: https://dpdpa.com/dpdpa2023/chapter-2/section6.html
- DPDP Act, section 13: https://dpdpa.com/dpdpa2023/chapter-3/section13.html
- AZB and Partners, "India's DPDP Act: phased rollout and key compliance milestones": https://www.azbpartners.com/bank/indias-digital-personal-data-protection-act-phased-rollout-and-key-compliance-milestones/
- Taxmann, "India's DPDP Act and Rules 2025: timeline, obligations, enforcement": https://www.taxmann.com/post/blog/analysis-indias-dpdp-act-and-rules/
- KPMG, "DPDP Rules 2025: guidance to DPDP Act implementation": https://assets.kpmg.com/content/dam/kpmgsites/in/pdf/2025/11/dpdp-rules-2025-guidance-to-dpdp-act-implementation.pdf
- Cyril Amarchand Mangaldas, client alert on the DPDP Rules, November 2025: https://www.cyrilshroff.com/wp-content/uploads/2025/11/Client-Alert-DPDP-Rules-Nov-2025.pdf
- Bar and Bench, "Legitimate use exemption for employee data under the DPDP Act": https://www.barandbench.com/law-firms/view-point/navigating-legitimate-use-exemption-employee-data-digital-personal-data-protection-act-2023
- LiveLaw, "India's Data Protection Board: established in law, absent in fact" (1 August 2026): https://www.livelaw.in/articles/india-data-protection-board-established-law-543751
- Nishith Desai Associates, "Government notifies rules with respect to protection of data under the IT Act" (SPDI Rules): https://nishithdesai.com/research-and-articles/hotline/technology-law-analysis/government-notifies-rules-with-respect-to-protection-of-data-under-the-information-technology-act-2000-5022
- Nishith Desai Associates, "Clarification to the Indian data protection laws" (MeitY press note, 24 August 2011): https://www.nishithdesai.com/research-and-articles/hotline/technology-law-analysis/clarification-to-the-indian-data-protection-laws-5023

- PSA Legal, "New CERT-In directions: overview and implications": https://psalegal.com/new-cert-in-directions-overview-and-implications/
- Mondaq, "The Consumer Protection (E-Commerce) Rules, 2020": https://mondaq.com/india/dodd-frank-consumer-protection-act/985606/the-consumer-protection-e-commerce-rules-2020
- IndiaLaw, "A summary of the Consumer Protection (E-Commerce) Rules, 2020": https://www.indialaw.in/blog/consumer-protection-e-commerce-rules/
- Supreme Court, National Insurance Co. v Harsolia Motors, judgment of 13 April 2023: https://api.sci.gov.in/supremecourt/2005/5607/5607_2005_5_1501_43491_Judgement_13-Apr-2023.pdf
- TaxGuru, "Power to declare terms of contract null and void under the Consumer Protection Act 2019": https://taxguru.in/corporate-law/power-declare-terms-contract-null-void-under-consumer-protection-act-2019.html
- CGST Act section 36, period of retention of accounts: https://www.knowyourgst.com/gstlaw/cgst-act/36-period-of-retention-of-accounts-36/
- BDO India, CBIC clarifications on time limits after the 2022 Budget (credit notes, section 34): https://bdo.in/en-gb/insights/alerts-updates/indirect-tax-alert-cbic-clarifications-on-the-time-limit-for-compliances-pursuant-to-union-budget
- GST Council, Circular 137/7/2020 (refund vouchers for advances): https://www.gstcouncil.gov.in/sites/default/files/2024-06/circular_refund_137_7_2020.pdf
- Google Play Console Help, User Data policy: https://support.google.com/googleplay/android-developer/answer/10144311
- Google Play Console Help, app account deletion requirements: https://support.google.com/googleplay/android-developer/answer/13327111
- Razorpay Docs, business website details: https://razorpay.com/docs/payments/dashboard/account-settings/business-website-details/
- iPleaders, "Enforceability of clickwrap agreements in India": https://blog.ipleaders.in/enforceability-of-clickwrap-agreements-in-india-all-you-need-to-know/
- King Stubb and Kasiva, "Clickwrap contracts: best practices, enforcement": https://ksandk.com/information-technology/clickwrap-contracts-best-practices-enforcement-global-views/
- Supreme Court Observer, CORE v ECI-SPIC-SMO-MCML (unilateral appointment of arbitrators): https://www.scobserver.in/cases/appointment-of-arbitrators-by-ineligible-persons/
- iPleaders, "Pre-institution mediation under the Commercial Courts Act": https://blog.ipleaders.in/pre-institution-mediation-significant-highlight-commercial-courts-act/
- International Arbitration and Mediation Centre, Hyderabad: https://iamch.org.in
- Law.asia, "Council overrides arbitration agreement under MSMED Act" (Mahakali Foods): https://law.asia/council-overrides-msmed-act/
- AM Legals, "Arbitration clause cannot oust the jurisdiction of consumer courts" (Emaar MGF v Aftab Singh): https://amlegals.com/arbitration-clause-cannot-oust-the-jurisdiction-of-consumer-courts/
- FSSAI, Hygiene Rating Scheme: https://stg-old.fssai.gov.in/cms/hygiene-rating.php
- Deccan Chronicle, "Telangana sets up unified food and drugs authority" (TG-SAFE): https://www.deccanchronicle.com/southern-states/telangana/telangana-sets-up-unified-food-and-drugs-authority-1979658
- Insecticides Rules, 1971 (rule 10, pest control operator licence): https://www.tnagrisnet.tn.gov.in/includes/docs/insecticides_rules_1971.pdf

- TrustPlate (subjects only): https://trustplate.in